Lab 5: Static Code Analysis — Complete Report

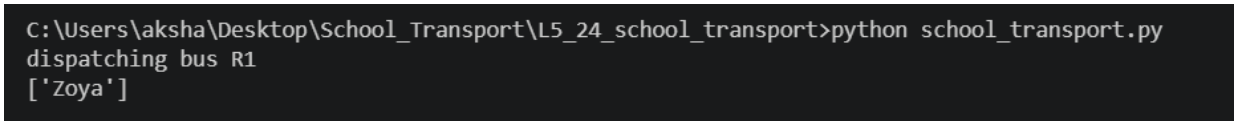
Pylint, Bandit and Flake8 — Outputs Before and After Fixes, Program Output, and Issues Resolved

Student: Akshat Agarwal | SRN: PES1UG24AM024
Program: school_transport.py — School Bus Transport Register
Repository: https://github.com/Akshat1686/L5_school_transport_024
Original repository: https://github.com/SETAPESU26/L5_24_school_transport

This report combines, in one document: (1) the program's execution output, (2) the complete outputs of Pylint, Bandit and Flake8 on the original file (before fixes) and on the cleaned file (after fixes), and (3) every issue that was found and how it was resolved. The cleaned program's behaviour is identical to the original.

1. Program Execution Output

Running the cleaned program (python school_transport.py) on Windows produced the following output in the terminal:



Terminal output of the cleaned program (screenshot provided by the student).

Transcript of the terminal output:

```
C:\Users\aksha\Desktop\School_Transport\L5_24_school_transport>python school_transport.py
dispatching bus R1
['Zoya']
```

The run also writes the route R1 roster to route_r1.txt. Contents of route_r1.txt from that run:

```
Tara
Kabir
```

This matches the original program's output exactly — the fixes changed the code's quality, security and style, not its behaviour.

2. Results Summary — Before vs After

Tool	Before (original file)	After (cleaned file)
Pylint	4.00 / 10 — 18 messages	10.00 / 10 — no messages (target > 9.5 met)
Bandit	4 issues — 1 High, 1 Medium, 2 Low	0 issues — "No issues identified"

Flake8	9 violations	0 violations

3. Pylint Output

Command: pylint school_transport.py (final run also enforces --fail-under=9.5)

Before fixes — score 4.00/10

```
************* Module school_transport
school_transport.py:5:0: C0301: Line too long (110/100) (line-too-long)
school_transport.py:9:0: C0301: Line too long (116/100) (line-too-long)
school_transport.py:1:0: C0114: Missing module docstring (missing-module-docstring)
school_transport.py:8:0: C0116: Missing function or method docstring (missing-function-docstring)
school_transport.py:8:0: C0103: Function name "enrollRider" doesn't conform to snake_case naming
style (invalid-name)
school_transport.py:13:0: C0116: Missing function or method docstring (missing-function-
docstring)
school_transport.py:13:0: C0103: Function name "routeRoster" doesn't conform to snake_case naming
style (invalid-name)
school_transport.py:13:23: W0613: Unused argument 'driver' (unused-argument)
school_transport.py:17:0: C0116: Missing function or method docstring (missing-function-
docstring)
school_transport.py:17:0: C0103: Function name "exportRoster" doesn't conform to snake_case
naming style (invalid-name)
school_transport.py:18:10: W1514: Using open without explicitly specifying an encoding
(unspecified-encoding)
school_transport.py:18:10: R1732: Consider using 'with' for resource-allocating operations
(consider-using-with)
school_transport.py:23:0: C0116: Missing function or method docstring (missing-function-
docstring)
school_transport.py:23:0: C0103: Function name "dispatchAlert" doesn't conform to snake_case
naming style (invalid-name)
school_transport.py:27:0: C0116: Missing function or method docstring (missing-function-
docstring)
school_transport.py:27:0: C0103: Function name "feeCollected" doesn't conform to snake_case
naming style (invalid-name)
school_transport.py:30:4: W0702: No exception type(s) specified (bare-except)
school_transport.py:34:0: C0116: Missing function or method docstring (missing-function-
docstring)

-----------------------------------
Your code has been rated at 4.00/10
```

After fixes — score 10.00/10

```

-----------------------------------
Your code has been rated at 10.00/10
```

4. Bandit Output

Command: bandit -r school_transport.py

Before fixes — 4 issues (1 High, 1 Medium, 2 Low)

```
[main]      INFO    profile include tests: None
[main]      INFO    profile exclude tests: None
```

```
[main]      INFO   cli include tests: None
[main]      INFO   cli exclude tests: None
[main]      INFO   running on Python 3.12.3
Run started:2026-10-23 06:06:27.386330+00:00

Test results:
>> Issue: [B404:blacklist] Consider possible security implications associated with the subprocess
module.
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b404-
import-subprocess
   Location: ./school_transport.py:1:0
1    import subprocess
2    import sqlite3
3

--------------------------------------------------
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based
query construction.
   Severity: Medium   Confidence: Medium
   CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html
   Location: ./school_transport.py:9:19
8    def enrollRider(student,route,stop,fee):
9        conn.execute(f"INSERT INTO riders (student, route, stop, fee) VALUES ('{student}',
'{route}', '{stop}', {fee})")
10       conn.commit()

--------------------------------------------------
>> Issue: [B602:subprocess_popen_with_shell_equals_true] subprocess call with shell=True
identified, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/plugins/b602_subprocess_popen_with_shell_equals_true.html
   Location: ./school_transport.py:24:4
23   def dispatchAlert(route):
24       subprocess.run("echo dispatching bus " + route, shell=True, check=False)
25

--------------------------------------------------
>> Issue: [B101:assert_used] Use of assert detected. The enclosed code will be removed when
compiling to optimised byte code.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b101_assert_used.html
   Location: ./school_transport.py:38:4
37       enrollRider("Zoya", "R2", "Fort Gate", 2100)
38       assert feeCollected("R1") == 3600
39       exportRoster("route_r1.txt", "R1")

--------------------------------------------------

Code scanned:
     Total lines of code: 30
     Total lines skipped (#nosec): 0
     Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
     Total issues (by severity):
```

```
            Undefined: 0
            Low: 2
            Medium: 1
            High: 1
     Total issues (by confidence):
            Undefined: 0
            Low: 0
            Medium: 1
            High: 3
Files skipped (0):
```

After fixes — no issues identified

```
Run started:2026-10-23 05:55:57.358616+00:00

Test results:
     No issues identified.

Code scanned:
     Total lines of code: 68
     Total lines skipped (#nosec): 0
     Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
     Total issues (by severity):
            Undefined: 0
            Low: 0
            Medium: 0
            High: 0
     Total issues (by confidence):
            Undefined: 0
            Low: 0
            Medium: 0
            High: 0
Files skipped (0):
```

Note: one Bandit finding (B101, assert used) survived the first clean-up and kept the GitHub Actions Bandit step failing; it was fixed by replacing the assert with an explicit check, after which Bandit reported no issues.

5. Flake8 Output

Command: flake8 school_transport.py

Before fixes — 9 violations

```
school_transport.py:5:80: E501 line too long (110 > 79 characters)
school_transport.py:8:24: E231 missing whitespace after ','
school_transport.py:8:30: E231 missing whitespace after ','
school_transport.py:8:35: E231 missing whitespace after ','
school_transport.py:9:80: E501 line too long (116 > 79 characters)
school_transport.py:14:80: E501 line too long (95 > 79 characters)
school_transport.py:23:1: E302 expected 2 blank lines, found 1
school_transport.py:29:80: E501 line too long (98 > 79 characters)
school_transport.py:30:5: E722 do not use bare 'except'
```

After fixes — 0 violations

Flake8 produced no output at all on the cleaned file (empty report), which means zero violations.

6. Issues Found and Resolved

Line numbers refer to the original school_transport.py. Thirteen issues are documented — well above the minimum of four required — with High and Medium severity findings first.

Issue	Type	Line(s)	Description	Fix Approach
1. subprocess call with shell=True (Bandit B602, High)	Security	24	subprocess.run("echo dispatching bus " + route, shell=True) builds a shell command from a variable. If route contained shell metacharacters, the shell would execute them — command injection (CWE-78).	Removed subprocess entirely; dispatch_alert() now uses print(f"dispatching bus {route}") — no shell is ever invoked.
2. SQL injection via f-string query (Bandit B608, Medium)	Security	9	enrollRider() interpolated student, route, stop and fee directly into the INSERT statement. A quote in a name could break out and inject arbitrary SQL (CWE-89).	Parameterised query: INSERT INTO riders (...) VALUES (?, ?, ?, ?) with values passed as a tuple, so they are treated as data, never SQL.
3. Import of subprocess module (Bandit B404, Low)	Security	1	Bandit flags any subprocess import because the module is frequently misused with a shell.	Import removed together with the B602 fix — the module is no longer needed.
4. assert used as a runtime check (Bandit B101, Low)	Security / Bug	38	assert feeCollected("R1") == 3600 was the only validation of the fee total, but Python strips asserts under -O, so the check could silently disappear (CWE-703). Last remaining Bandit finding; kept CI failing.	Replaced with an explicit check: compute total_r1 and raise SystemExit with a clear message if it is not 3600.
5. Bare except: (Pylint W0702, Flake8 E722)	Bug	30	feeCollected() caught every exception and silently returned 0, hiding real failures behind a wrong-looking total.	Removed try/except. fee_collected() returns result[0] or 0, which also handles SUM(fee) returning None for a route with no riders.
6. Non-snake_case function names (Pylint C0103)	Convention	8, 13, 17, 23, 27	enrollRider, routeRoster, exportRoster,	Renamed all to snake_case: enroll_rider,

			dispatchAlert, feeCollected use camelCase, violating PEP 8.	route_roster, export_roster, dispatch_alert, fee_collected; all call sites updated.
7. Missing docstrings (Pylint C0114, C0116)	Convention	1, 8, 13, 17, 23, 27, 34	The module and every function lacked a docstring, so intent could only be learned by reading each body.	Added a module docstring and a docstring to every function.
8. Unused argument 'driver' (Pylint W0613)	Warning	13	routeRoster(route, driver) accepted a driver argument that was never used; callers passed None and "Mr. Das" inconsistently.	Removed the driver parameter from route_roster() and all call sites.
9. File opened without 'with' and without encoding (Pylint R1732, W1514)	Refactor / Warning	18	Bare open(path, "w") with manual close(): an exception would leave the file open, and no encoding= makes output platform-dependent.	with open(path, "w", encoding="utf-8") as output_file: — always closed, encoding explicit.
10. Lines too long (Pylint C0301, Flake8 E501)	Style	5, 9 (also 14, 29 for Flake8)	CREATE TABLE, INSERT and SELECT statements were single lines of 95–116 characters, hurting readability and breaking PEP 8.	Wrapped SQL statements across multiple lines so no line exceeds the limit.
11. Missing whitespace after commas (Flake8 E231)	Style	8	def enrollRider(student,route,stop,fee): had no spaces after the commas.	Added the missing spaces; formatting kept clean throughout the rewrite.
12. Expected 2 blank lines before function (Flake8 E302)	Style	23	dispatchAlert() was preceded by only one blank line; PEP 8 requires two around top-level definitions.	Corrected blank-line spacing around every top-level definition.
13. Global database connection, unguarded script entry (supporting refactor)	Design	4–5, 44	The SQLite connection was a module-level global created at import time and main() ran unguarded, so importing the file connected to a database and ran the demo.	create_database() builds the connection; it is passed explicitly, closed in a finally block, and entry is guarded by if __name__ == "__main__":.

7. Verification

After the fixes, all three tools were re-run on the cleaned file: Pylint 10.00/10 (above the 9.5 target), Bandit "No issues identified", Flake8 zero violations. The repository's GitHub Actions workflows (Pylint Code Analysis and Complete Static Code Analysis) run all three tools on every push, generate pylint_report.txt, bandit_report.txt and flake8_report.txt, and upload them as run artifacts; both workflows conclude Success. The three final report files are also committed in the reports/ folder of the repository for direct viewing. Full details of each issue are in issues.md and the reflection answers are in reflection.md in the repository.